Compliance Primer: What CUI, NIST, CMMC, HIPAA, and GDPR Mean for Log Data

A plain-English guide for people who keep hearing these acronyms and want to understand what they actually mean, what they require, and how they apply to the mundane problem of exporting log samples from Splunk.

Who this is for

You've heard of CUI, NIST 800-171, CMMC, HIPAA, or GDPR. Maybe you've been told you need to comply with one or more of them. Maybe you're evaluating a log-scrubbing tool (like **Paydirt**, a browser-based scrubber, or its command-line counterpart `log_scrubber.py`) and want to understand why it exists. You are not a compliance officer, not a lawyer, and not a security engineer with formal training in this area. You want to walk away from this document able to have a sensible conversation about these topics without bluffing.

This is not legal advice. It is an operator's introduction to a complex regulatory landscape.

The one-paragraph summary

Governments and industries have a handful of different rule sets for protecting sensitive information. Most of them agree on the same practical point: if data can identify a person, reveal a health condition, or expose government-regulated information, it must be protected in storage, in transit, and when shared. Log data from enterprise systems routinely contains all three categories because logs ingest everything: usernames, email addresses, IP addresses, patient identifiers, contract references, cloud account IDs. When you export log samples to share with a tool, a vendor, or an LLM, you are performing a data transfer that the regulations care about. Scrubbing the export before it leaves your laptop is the simplest way to turn a potentially risky transfer into a safe one.

Section 1: What is CUI, really?

CUI stands for **Controlled Unclassified Information**. It is information the US federal government cares about protecting even though it is not classified. Think of it as a middle tier: not "Top Secret," but also not "public."

Before 2010, the federal government had a sprawling mess of marking schemes for sensitive-but-unclassified information: FOUO (For Official Use Only), SBU (Sensitive But Unclassified), LES (Law Enforcement Sensitive), OUO (Official Use Only), and dozens of agency-specific variants. Different agencies used different terms for overlapping categories, and contractors were often confused about what to protect and how.

Executive Order 13556, signed in 2010, consolidated all of this into a single category called CUI. The National Archives (NARA) runs the CUI program and publishes the CUI Registry, which lists every approved category (privacy, proprietary, export control, law enforcement, and others).

How to recognize CUI in the wild

CUI is identified by **markings**, not by content patterns. When you see one of the following, you are looking at CUI:

Banner markings appear at the top of documents, in email subject lines, or pasted into tickets. They look like this:

- `CUI` (the generic marking)
- `CUI//BASIC` (no specified category)
- `CUI//SP-PRVCY` (Privacy)
- `CUI//SP-PROPIN` (Proprietary)
- `CUI//SP-EXPT` (Export Controlled, often ITAR or EAR-related)
- `CUI//SP-LEI` (Law Enforcement)
- `CUI//SP-CTI` (Controlled Technical Information, common in DoD work)
- `CONTROLLED//SP-...` (the verbose form of the same thing)

Portion markings appear inline, usually just before a paragraph or field that contains CUI:

- `(CUI)`
- `(CUI//SP-PRVCY)`
- `(U//FOUO)` - the legacy FOUO marking, still widespread
- `(U)` for Unclassified, `(C)` for Confidential

Legacy markings predate the 2010 consolidation but still appear in older documents, tickets, and emails. Treat these as CUI-equivalent for protection purposes:

- `FOUO`, `SBU`, `LES`, `OUO`, `LIMDIS`, `NOFORN`, `FEDCON`, `ORCON`

CUI-adjacent content isn't a marking itself, but strongly suggests CUI is nearby. If you see these terms in filenames, email subjects, or log messages, the surrounding content is likely CUI-regulated:

- `ITAR` (International Traffic in Arms Regulations)
- `EAR99`, `ECCN` (Export Administration Regulations)
- `DD 254` (Department of Defense Contract Security Classification Specification)
- `FCI` (Federal Contract Information)

Why CUI matters for log data

If you handle a government contract that produces or references CUI, then log files from the systems involved may themselves contain CUI. A log line saying "User uploaded file ITAR-Q3-Export-Review.pdf" is a CUI indicator even if the log entry itself looks innocuous. A ticket description pasted into an email body that ends up in a Splunk index could carry a `CUI//SP-PRVCY` banner.

You cannot detect CUI by pattern-matching on content the way you can detect a social security number. You have to recognize the markings. This is why the log scrubber treats any line containing a CUI marking as a whole-line redaction: if the marking is present, the content is sensitive by definition, and you don't try to guess which parts.

Section 2: NIST SP 800-171

NIST is the **National Institute of Standards and Technology**, a US government agency that publishes technical standards. They publish hundreds of Special Publications (SPs). **SP 800-171** is the one that specifies how to protect CUI when it lives in nonfederal systems: a contractor's laptops, a subcontractor's file server, a cloud tenant, a Splunk instance.

What it contains

NIST SP 800-171 is a list of security requirements organized into control families: access control, audit and accountability, configuration management, identification and authentication, incident response, and so on. The current version is **Revision 3**, published in May 2024, and it contains roughly 110 security requirements.

Each requirement is a specific thing you have to do or prove. Examples paraphrased from the spec:

- Limit system access to authorized users.
- Audit and log user activity.
- Protect the confidentiality of CUI at rest.
- Protect the confidentiality of CUI in transit.
- Sanitize system media before disposal.

Why it matters

NIST SP 800-171 is not a law. It is a specification. It becomes legally binding when a government contract incorporates it by reference, which is standard for DoD contracts (DFARS clause 252.204-7012) and is becoming standard for GSA, NASA, and civilian agency contracts.

If you are doing any work for the federal government and your systems touch CUI, compliance with NIST SP 800-171 is almost certainly a contractual requirement. The newer GSA procedural guide published in January 2026 made Rev. 3 the required baseline for GSA contractors, and other agencies are expected to follow.

How it relates to log scrubbing

Several SP 800-171 requirements have direct implications for how you handle log samples:

- **3.1 (Access Control):** You can't email raw CUI-containing logs to a vendor without controls. Scrubbing the export first may move the data out of the CUI access-control scope.
- **3.8 (Media Protection):** Exporting a CSV to your Downloads folder is creating a new copy of CUI on unencrypted media. Scrubbing before export limits exposure.
- **3.13 (System and Communications Protection):** If you're sending log samples to an LLM for analysis, that transmission is covered by the confidentiality-in-transit requirement. Scrubbing first changes what's actually being transmitted.

The scrubber doesn't make you "800-171 compliant." Nothing a single tool can do makes you compliant; compliance is an organizational posture, not a feature. But the scrubber reduces the scope of what's covered by 800-171 when you handle log exports, which is a practical compliance win.

A note on NIST SP 800-53

If you've been in security-review meetings for any length of time, you've probably heard NIST SP 800-53 mentioned. Here's how it relates.

NIST SP 800-53 (currently Revision 5) is the master catalog of security and privacy controls for federal information systems. It's large: roughly 1,189 controls and control enhancements across 20 families. SP 800-171 is essentially a carefully curated subset of 800-53, reorganized and simplified for the contractor context. Appendix D of 800-171 provides a direct mapping showing which 800-53 control each 800-171 requirement traces back to.

Most contractors interact with 800-53 indirectly rather than directly. Three paths are common:

- **FedRAMP.** Cloud service providers that handle federal data must be authorized at a FedRAMP baseline (Low, Moderate, or High), and those baselines are 800-53 selections. If your organization uses a cloud service (AWS, Azure, Splunk Cloud) to store or process CUI, that cloud provider is implementing 800-53 controls on your behalf.
- **GSA 2026 guidance.** The GSA procedural guide published in January 2026 references "selected requirements from NIST SP 800-172 (draft) and certain privacy controls from NIST SP 800-53 Revision 5" alongside the primary 800-171 Rev. 3 baseline. Direct 800-53 references are starting to bleed into contractor requirements.
- **Civilian agency contracts.** Agencies outside DoD sometimes reference 800-53 directly rather than going through the 800-171 abstraction.

The part of 800-53 most relevant to log data is the **Audit and Accountability (AU) control family**, which includes AU-2 (Event Logging), AU-3 (Content of Audit Records), AU-9 (Protection of Audit Information), AU-11 (Audit Record Retention), and AU-12 (Audit Record Generation). These controls are what *produce* the log data in the first place. They require logs to contain identifiable information (user IDs, timestamps, source addresses) because that's what makes logs useful for incident response and forensics.

This creates the core tension that scrubbing tools address: 800-53 compels you to log identifiable events, while 800-171, HIPAA, and GDPR constrain how you can handle those logs afterward. Scrubbing lives in that tension. It preserves the operational value of logs for their primary purpose (audit, forensics, troubleshooting) while reducing the regulated-content footprint when samples have to leave their protected environment.

Section 3: CMMC

CMMC stands for **Cybersecurity Maturity Model Certification**. It is the DoD's compliance enforcement program for NIST SP 800-171. CMMC asks the question: how do we know you're actually implementing the 800-171 controls you say you are?

Before CMMC, DoD contractors self-attested to SP 800-171 compliance. Investigations revealed widespread inflation and inaccuracy; contractors claimed compliance they had not actually implemented. CMMC replaces self-attestation with a tiered verification model.

The three levels

- **Level 1**: Applies to contractors handling only FCI (Federal Contract Information, a narrower category than CUI). Requires 17 basic security controls. Self-assessed annually.
- **Level 2**: Applies to contractors handling CUI. Requires all 110 NIST SP 800-171 controls. Assessed by a Certified Third-Party Assessment Organization (C3PAO) every three years, with annual affirmations. **This is the level most DoD contractors care about.**
- **Level 3**: Applies to contractors handling CUI associated with the most sensitive DoD programs. Requires the Level 2 controls plus 24 additional controls from NIST SP 800-172. Assessed by DoD's own assessment body (DIBCAC).

The current state (as of April 2026)

The CMMC final rule went into effect on November 10, 2025. Implementation is phased:

- **Phase 1 (started November 10, 2025):** CMMC assessment requirements appear in DoD solicitations. Most contractors can still use self-assessment for Level 2.
- **Phase 2 (starts November 10, 2026):** C3PAO-certified Level 2 becomes the default for contracts involving CUI. This is the big deadline that DoD contractors are racing toward right now.
- **Phase 3 (November 10, 2027):** Level 3 requirements start appearing; C3PAO Level 2 becomes mandatory across the board.
- **Phase 4 (November 10, 2028):** Full implementation, applying to all contracts and option periods.

Why it matters

If your organization is a DoD contractor or subcontractor, CMMC certification is the difference between being able to bid on contracts and being locked out. Subcontractors flow down CMMC requirements from primes, so even companies that don't contract directly with DoD may be pulled in.

The current capacity crisis is real: an estimated 76,000 organizations need Level 2 C3PAO certification, and as of early 2026 fewer than 1,100 had completed it. There are roughly 80 authorized C3PAOs, many booked 18+ months out. Organizations that haven't started preparing for Phase 2 are already behind.

How it relates to log scrubbing

CMMC assessments look at how you handle CUI across your entire operational footprint, including how you transfer data to third parties, how you use cloud services, and how you handle logs. A workflow that exports raw CUI-containing logs to a user's laptop and emails them to a vendor is the kind of thing an assessor will ask about. A workflow that exports, scrubs locally, and transmits only sanitized data is much easier to justify.

Section 4: HIPAA and PHI

HIPAA is the **Health Insurance Portability and Accountability Act** of 1996. It protects **Protected Health Information (PHI)**, which is individually identifiable health information held by a "covered entity" (healthcare providers, health plans, healthcare clearinghouses) or their business associates.

PHI is health data combined with any identifier. A vital-signs dataset with no identifiers is not PHI. The same dataset with a medical record number attached is PHI.

The 18 identifiers

HHS defines 18 identifier types that, when linked to health data, create PHI:

1. Names
2. Geographic subdivisions smaller than a state (street address, city, county, zip code)
3. Dates (birth, admission, discharge, death) except year alone
4. Telephone numbers
5. Fax numbers
6. Email addresses
7. Social Security numbers
8. Medical record numbers
9. Health plan beneficiary numbers
10. Account numbers
11. Certificate/license numbers

12. Vehicle identifiers (VINs, license plates)
13. Device identifiers and serial numbers
14. Web URLs
15. IP addresses
16. Biometric identifiers (fingerprints, voiceprints)
17. Full-face photographs
18. Any other unique identifying number, characteristic, or code

Notice how many of these are also things that routinely appear in logs: IP addresses, email addresses, URLs, device identifiers, account numbers.

Why it matters for logs

If your organization operates in healthcare-adjacent work (health insurance, hospital IT, pharma research, medical device telemetry), the logs are almost certainly carrying PHI even when the primary system isn't a clinical system. A login audit log from a hospital employee portal carries email addresses and timestamps, which combined with the context ("employee of St. Elsewhere Hospital") becomes PHI.

HIPAA violations carry substantial civil penalties and, in severe cases, criminal penalties for the individuals responsible. The scrubber's built-in patterns (SSN, phone, email, IP addresses) directly address most of the 18 identifiers, which is why this tool is useful in HIPAA-regulated environments even when CUI isn't involved.

De-identification

HIPAA's "Safe Harbor" method says that if you strip all 18 identifiers from a dataset, the remaining health information is de-identified and no longer subject to HIPAA. This is exactly the scrubbing workflow: remove the identifiers, keep the operational content. The scrubber's approach is structurally aligned with HIPAA Safe Harbor, though the tool alone does not certify a dataset as de-identified. A formal de-identification for HIPAA purposes requires either expert determination or an auditable Safe Harbor process.

Section 5: GDPR

GDPR is the EU's **General Data Protection Regulation**, effective since May 2018. It is the most expansive data protection law in effect today. Most non-EU countries with modern data protection laws (UK, Brazil, California via CCPA/CPRA) have modeled their frameworks on GDPR.

What GDPR protects

GDPR protects "personal data," defined in Article 4(1) as any information relating to an identified or identifiable natural person. This definition is intentionally broad. It includes:

- Names, addresses, ID numbers (obvious)
- Email addresses, phone numbers (obvious)
- **IP addresses** (this is the one people get wrong)
- Device IDs, cookies, advertising identifiers
- Location data
- Combinations of data that together could identify someone (even if no single element does)

The Court of Justice of the EU confirmed in 2016 (Breyer v. Germany) that IP addresses, including dynamic ones, constitute personal data when the party holding them could reasonably obtain additional information to

identify the individual. A September 2025 ruling (EDPS v. SRB) refined this somewhat for pseudonymized data, but the 2016 framework remains the operative standard in 2026.

This is why the log scrubber redacts IP addresses by default: even if you think the IPs in your logs aren't identifiable, under GDPR they almost certainly are.

Why it matters for logs

If any users, customers, or employees whose data appears in your logs are EU residents, GDPR applies to you regardless of where your company is based. Logs are explicitly covered: analytics logs, server access logs, audit logs, and security logs all contain personal data for GDPR purposes.

GDPR penalties are up to 4% of annual global revenue or 20 million euros, whichever is higher. Organizations have been fined tens of millions of euros for mishandling log data.

How it relates to log scrubbing

GDPR's Article 5 requires "data minimization": only process personal data that's necessary for a specified purpose. If you're exporting a Splunk sample to analyze a query-parsing problem, you don't need the real IP addresses; you need the query structure. Scrubbing before export is data minimization in practice.

GDPR also imposes strict requirements on international data transfers. If you're sending logs to a vendor outside the EU, that transfer needs legal justification. Scrubbing reduces the personal-data content of the transfer, which simplifies the legal analysis.

Section 6: How these frameworks relate to each other

These aren't five separate worlds. They overlap extensively.

- **NIST SP 800-171** is the control specification. It tells you *how* to protect CUI.
- **CMMC** is the enforcement mechanism for 800-171 in DoD contracts. It tells you *how to prove* you're following 800-171.
- **HIPAA** is the parallel framework for health information, with its own controls and enforcement.
- **GDPR** is the parallel framework for personal data of EU residents.
- **CUI** is the category of information that triggers 800-171 and CMMC.
- **PHI** is the category of information that triggers HIPAA.
- **Personal data** is the category that triggers GDPR.

A single organization can be subject to all of them simultaneously. A company doing healthcare work on a DoD contract with EU employees is subject to CMMC (because DoD), HIPAA (because healthcare), and GDPR (because EU residents). The compliance requirements layer rather than override.

The log scrubber is useful across all of them because the underlying problem is the same: you have logs that contain a mix of regulated identifier types, and you need to transmit a version of those logs that doesn't contain the identifiers.

Section 7: Why this matters for the LLM workflow specifically

Feeding unscrubbed logs to an LLM, even an internal one, creates a set of problems that scrubbing directly addresses:

Retention. Most LLM services retain prompts for some period (for abuse monitoring, model improvement, or debugging). If your prompt contained CUI, PHI, or personal data, the LLM provider is now a processor of that data, and you've created a new data-handling relationship that has its own compliance implications.

Re-emission. LLMs can include fragments of their training or context in their outputs, sometimes verbatim. A log containing a real user's email address becomes a piece of text the LLM might reproduce in a later answer to a different user.

Audit trail. If you're ever asked "where did CUI get shared outside your boundary?" by a CMMC assessor or a GDPR supervisory authority, you need an answer. "We ran every log export through an automated scrubber that removes CUI markings, credentials, PII, and PHI identifiers" is a good answer. "We pasted logs into an LLM and hoped for the best" is a bad answer.

Vendor assessment. Using an LLM from a vendor is a data-transfer activity that most compliance regimes require you to assess: does the vendor have adequate security, retention policies, data processing agreements? Scrubbing the data before it leaves your environment reduces the vendor-assessment burden, because the vendor never sees regulated data in the first place.

Section 8: What the scrubber does, mapped to compliance categories

Each layer of the scrubber addresses specific compliance concerns:

Scrubber layer	What it catches	Which frameworks it helps with
CUI marking detection	Banner, portion, legacy, adjacent markings	CMMC, NIST SP 800-171
Credential patterns	AWS keys, GitHub PATs, tokens, private keys, auth headers	All (credentials in logs are a breach regardless of framework)
PII patterns	SSN, phone, credit cards (Luhn-validated), Windows SIDs	HIPAA, GDPR, state privacy laws
PHI patterns	NPI, medical record identifiers via config	HIPAA
Email addresses	All email formats	HIPAA (identifier #6), GDPR (personal data), CMMC (CUI adjacent)
IP addresses	IPv4 addresses	HIPAA (identifier #15), GDPR (online identifier)
Hostnames	FQDNs, AWS ip- hostnames	GDPR (location/environment data), general OPSEC
JSON field rules	Nested fields in structured logs like CloudTrail, GuardDuty	All (flexible tool for environment-specific identifiers)
Text substitution rules	Organization names, internal domains, custom identifiers	All (flexible tool for organization-specific data)

Section 9: What the scrubber does NOT do

Being honest about the limits is important.

It is not a certified compliance product. It's a detection-and-redaction tool. No single tool makes any organization CMMC-certified, HIPAA-compliant, or GDPR-compliant. Compliance is an organizational posture with documented policies, trained staff, audit trails, and verified controls.

It cannot detect unmarked CUI. If a log contains CUI content but no marking (because someone forgot to mark it, or because the marking got stripped upstream), the scrubber's CUI layer will not catch it. The other layers (PII, credentials, etc.) may catch some of the constituent identifiers, but marking-based detection is inherently limited to what's actually marked.

It cannot identify domain-specific identifiers it doesn't know about. Internal employee IDs, custom ticket number formats, proprietary file path structures - these need to be added to the config. The tool ships with sensible defaults, but every organization has unique data shapes.

It cannot detect bare personal names or free-text content. This is worth calling out explicitly because it is the most common blind spot. Paydirt detects values by shape (regex patterns for IPs, emails, tokens, SSNs, etc.) or by structured field name (JSON keys, CSV columns, Splunk fieldsummary fields targeted with `@json` rules). It cannot detect a value like `John Smith` in an unstructured `_raw` event, a customer name in a `comment` or `description` field, an internal project or customer code name, a person-named asset such as `JSMITH-LAPTOP`, branch or team names, or stack traces that echo user input. Two-capitalized-word patterns are not a viable detection signal because their false-positive rate on log data is catastrophic ("New York", "User Agent", "Last Modified", every product name). For structured cases the `@json` shortcut closes the gap; for unstructured narrative, reviewer attention is the only control. **Treat manual review of the scrubbed output as a residual control requirement, not an optional sanity check.** Compliance reviewers evaluating Paydirt for inclusion in a workflow should document this responsibility on the human reviewer in the relevant SOP, not assume the tool closes it.

It is not a substitute for manual review. Always spot-check the output, especially when setting up a new log source or configuration. Automated scrubbing handles known patterns; human review catches the unexpected.

It is not a DLP (Data Loss Prevention) system. Enterprise DLP tools monitor data flows across the entire organization and enforce policies at network egress points. The scrubber is a focused utility for one specific workflow: cleaning Splunk exports before they're shared. Both have their place; they're not substitutes for each other.

Section 10: Further reading (authoritative sources)

These are the primary sources. When compliance questions get specific, go to these rather than secondary sources.

CUI:

- NARA CUI Registry - the authoritative list of CUI categories
- Executive Order 13556 - the 2010 order that created the CUI program
- 32 CFR Part 2002 - the regulation implementing CUI

NIST SP 800-171:

- NIST SP 800-171 Rev. 3 (current) - the current security requirements
- NIST SP 800-171A Rev. 3 - the assessment procedures
- NIST CUI Project Page - ongoing updates

CMMC:

- DoD CMMC Program Page - official program information
- 32 CFR Part 170 - the CMMC program rule
- DFARS 252.204-7021 - the contract clause

HIPAA:

- HHS HIPAA Home - the primary source
- HIPAA Privacy Rule (45 CFR Part 164) - the de-identification standards
- HHS De-Identification Guidance - Safe Harbor and Expert Determination methods

GDPR:

- Full GDPR text - searchable, annotated
- EDPB Guidelines - the European Data Protection Board's official interpretations
- Article 4 definitions - the key definitions including "personal data"

Appendix: A worked example

An engineer is troubleshooting a log-normalization issue at a DoD contractor's site. They need to export log samples from a Splunk instance on a locked-down laptop, review the field structures, and share a representative sample with a colleague or a vendor who can help work out the right normalization rules.

Without scrubbing: The engineer runs the export, gets a CSV with 20 raw events in their Downloads folder. The events contain real employee email addresses (GDPR personal data), real AWS account IDs (potentially sensitive under the DoD contract), some log lines with `FOUO` markings left over from a legacy system integration (CUI), and a few audit events with AWS access keys that leaked into debug logs (credentials). The engineer emails this CSV to the colleague. That email just transferred CUI and personal data across two laptops, one mail server, and whatever anti-malware appliances are in the path. Each of those is now in scope for a compliance audit.

With scrubbing: The engineer opens Paydirt in the browser, drops the CSV onto it, and downloads the scrubbed version. (If they're on a developer workstation with Python installed, they can run `log_scrubber.py` from the command line for the same result.) The scrubbed output has emails replaced with `user@example.com`, account IDs replaced with `000000000000`, FOUO-marked lines replaced with `[CUI-REDACTED: LEGACY:FOUO, 247 bytes]`, and AWS access keys replaced with placeholders. The engineer emails the scrubbed version. The email now contains no CUI, no personal data, and no credentials. The original regulated data never left the engineer's laptop. The compliance scope of the email is dramatically smaller.

The scrubbed version is still useful for the engineering task: the log structure is preserved, the field names are intact, the event timing is present. You can still work out a normalization mapping. You just can't identify the specific users, accounts, or contract references.

That's the whole game. The scrubber doesn't make compliance go away, but it makes the day-to-day engineering workflows dramatically easier to do compliantly.

Machine Data Insights Inc. *"There's Gold In That Data!"*® | machinedatainsights.com

Version 1.0 - April 25, 2026